

Tutorial 2 (Chapter 3 and 4)

Name :Hani Yamin Jamali

Id: 1221303155

Question 1: Describe three uses of a public-key cryptosystem

A public-key cryptosystem uses a public key and a private key to provide secure communication. Its three main uses are:

1. **Encryption:** The sender encrypts data using the receiver's public key, and only the receiver can decrypt it using their private key.
2. **Digital signatures:** The sender signs a message using their private key, and others verify it using the public key to confirm the sender and message integrity.
3. **Key exchange:** It helps two users securely agree on a shared session key, which can later be used for faster symmetric encryption.

Question 2: Discuss three misconceptions of the public-key cryptosystem

1. **Public-key cryptography replaces symmetric cryptography:** This is wrong because public-key encryption is slower. It is usually used for key exchange or signatures, while symmetric encryption protects large data.
2. **Public-key systems are always secure:** This is wrong because security depends on the algorithm, key size, padding, certificate validation, key storage, and correct implementation.
3. **Encryption and digital signatures are the same:** This is wrong because encryption protects confidentiality, while digital signatures prove authentication, integrity, and non-repudiation.

Question 3: Difference between a private key and a secret key

Aspect	Private Key	Secret Key
Cryptographic type	Used in asymmetric/public-key cryptography.	Used in symmetric-key cryptography.
Key sharing	Kept only by its owner and not shared.	Shared between two or more trusted parties.
Related key	Has a matching public key.	Usually the same key is used by both parties.
Main uses	Decrypting data encrypted with the public key and creating digital signatures.	Encrypting and decrypting data, or creating/verifying a MAC.
Example	RSA private key or ECDSA signing private key.	AES key or HMAC key.

In simple words, a private key belongs to one owner in a public-key pair, while a secret key is a shared key used by both parties in symmetric cryptography.

Question 4: Explain a digital signature

A digital signature is a cryptographic method used to prove that a message was created by the claimed sender and was not changed after signing. The sender usually creates a hash of the message and signs the hash using the sender's private key. The receiver then uses the sender's public key to verify the signature. If verification succeeds, the receiver gains confidence in three things: the message came from the signer, the message has integrity, and the signer cannot easily deny signing it later. Therefore, digital signatures support authentication, integrity, and non-repudiation.

Question 5: Explain a public-key certificate

A public-key certificate is a digital document that binds a person, organization, or server identity to a public key. It is normally issued and digitally signed by a trusted Certificate Authority (CA). The certificate usually contains the subject identity, the subject public key, the issuing CA, the validity period, a serial number, and the CA digital signature. When a browser connects to a secure website, it checks the website certificate and verifies that it was signed by a trusted CA. This helps users trust that the public key really belongs to the claimed website or entity.

Question 6: Digital envelope with digital signature

The following figure shows a digital envelope process that also includes a digital signature. The signature authenticates the message, while the digital envelope protects the session key and message confidentiality.

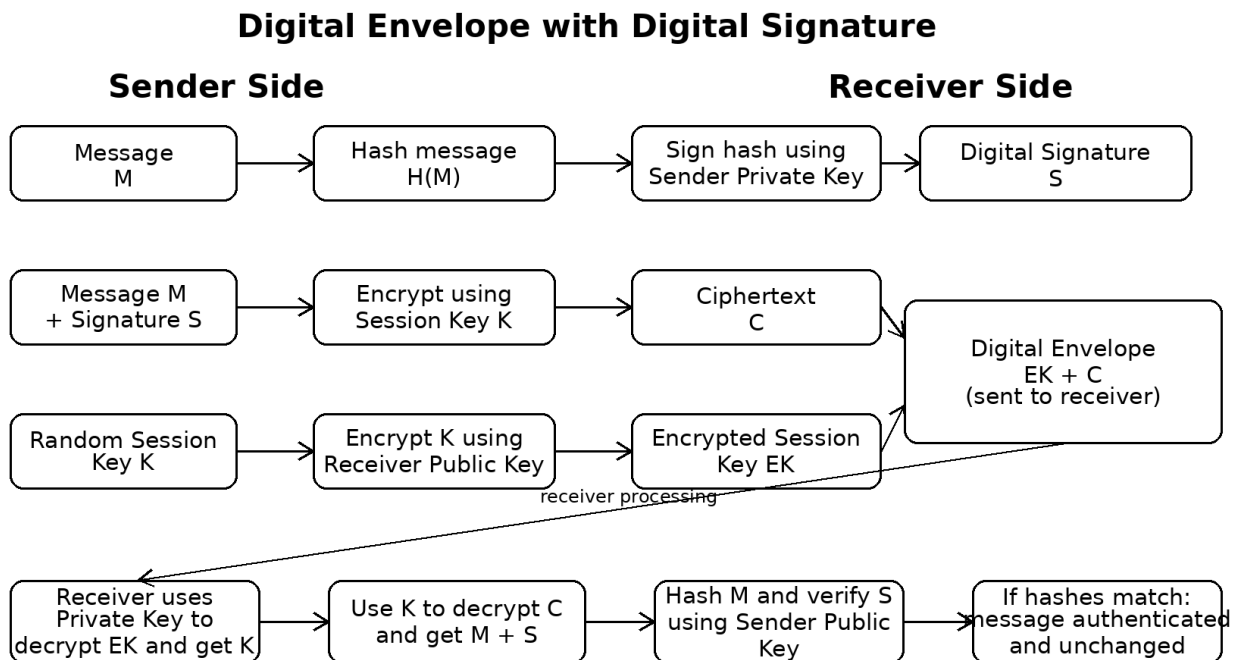


Figure 1. Digital envelope with digital signature for message authentication.

Explanation: First, the sender hashes the message and signs the hash using the sender's private key. This creates a digital signature. Then, the sender combines the message and signature and encrypts them using a random symmetric session key. The session key is encrypted using the receiver's public key. The encrypted session key and encrypted message are sent as the digital envelope. The receiver decrypts the session key using the receiver's private key, decrypts the message using the session key, and verifies the signature using the sender's public key. If the verification is successful, the receiver knows the message is authentic and unchanged.

Question 7: Two reduction-framework techniques

Chosen techniques: security games and hybrid arguments.

Technique 1: Security games

A security game is a formal experiment between a challenger and an adversary. The challenger represents the honest cryptographic system, while the adversary represents an attacker. The game normally includes setup, allowed queries, a challenge phase, and a final guess by the adversary. The adversary's advantage is calculated by comparing its success probability with random guessing. A cryptosystem is considered secure if every efficient adversary has only a negligible advantage (Boneh & Shoup, 2020; Shoup, 2004).

How it is built in the reduction framework: In a reduction proof, researchers assume that an adversary can win the security game against the cryptosystem. Then they build a reduction algorithm that uses this adversary as a subroutine to solve a known hard problem. For example, if an adversary can break the scheme, the reduction may use that adversary to solve RSA inversion, integer factorization, or the discrete logarithm problem. Therefore, breaking the scheme would imply breaking the hard mathematical assumption.

How it solves cryptosystem issues: Security games solve the issue of vague security claims. Instead of saying a scheme is simply “secure,” the game clearly defines what the attacker can do and what counts as a successful attack. This helps detect weaknesses such as chosen-plaintext attacks, chosen-ciphertext attacks, forgery attacks, replay attacks, and key-recovery attempts. It also makes security easier to compare across different schemes.

Technique 2: Hybrid arguments

A hybrid argument proves security by creating a sequence of small changes between a real game and an ideal game. Hybrid 0 is usually the real attack game. The final hybrid is an ideal game where the adversary has no useful advantage. Each pair of neighboring hybrids must be computationally indistinguishable. If the adversary cannot distinguish any neighboring games, then the adversary cannot distinguish the real system from the ideal secure system (Boneh & Shoup, 2020; Shoup, 2004).

How it is built in the reduction framework: The proof starts with the original system and gradually replaces real components with ideal or random components. Each replacement is justified using a cryptographic assumption or the security of an underlying primitive. If an adversary can notice the difference between two neighboring hybrids, then a reduction can use that adversary to break the related assumption. The total adversary advantage is bounded by adding the advantages across all hybrid steps.

How it solves cryptosystem issues: Hybrid arguments help analyze complex cryptosystems that have many parts, such as encryption, hashing, random nonces, key derivation, and authentication. Instead of proving everything in one difficult step, the proof checks one change at a time. This reduces proof complexity and helps find exactly which component would fail if the construction were insecure.

Question 8: Compare System A and System B

System A refers to RSA-based cryptography because it depends on the difficulty of factoring very large composite numbers. System B refers to Diffie-Hellman-style key agreement because it allows two parties to agree on a shared secret over a public network based on the discrete logarithm problem. NIST identifies RSA as integer-factorization cryptography and Diffie-Hellman as discrete-logarithm-based key establishment (NIST CSRC, 2018; NIST CSRC, 2019).

Aspect	System A: RSA / factoring-based	System B: Diffie-Hellman / discrete-log-based
Underlying hard mathematical problem	Integer factorization problem: it is easy to multiply two large primes, but difficult to factor their product.	Discrete logarithm problem: it is easy to compute exponentiation in a group, but difficult to recover the exponent from the result.
Type of cryptographic function	Mainly public-key encryption, decryption, signature, and key transport depending on the mode.	Key agreement/key exchange. It is designed to create a shared secret rather than directly encrypt a message.
Security foundation	Security is based on the assumed hardness of factoring large RSA moduli and the difficulty of reversing RSA without the private key.	Security is based on the assumed hardness of the discrete logarithm problem or Diffie-Hellman assumptions in the chosen group.
One-way function involved	Multiplication of large primes is easy, but factoring their product is hard. RSA modular exponentiation is also easy in one direction but hard to invert without the private key.	Modular or elliptic-curve exponentiation/scalar multiplication is easy, but finding the private exponent/scalar from the public value is hard.
Main strength	Suitable for public-key encryption/key transport and digital signatures when implemented with secure padding.	Suitable for establishing a shared secret over an insecure channel, especially when used as ephemeral Diffie-Hellman for forward secrecy.
Main concern	Improper padding, weak key sizes, and poor private-key protection can break security. It is also vulnerable to quantum attacks if large-scale quantum computers become practical.	Needs authentication to stop man-in-the-middle attacks. It also requires safe parameter choices and is vulnerable to quantum attacks if large-scale quantum computers become practical.

Justification

For secure key exchange, System B is more suitable because Diffie-Hellman is specifically designed to let two parties establish a shared secret over a public network. When authenticated and used with fresh ephemeral keys, it can also provide forward secrecy, meaning old recorded sessions remain protected even if a long-term private key is later compromised.

For encryption, System A is more appropriate because RSA is a public-key encryption/key-transport mechanism based on integer factorization. However, in real secure systems, RSA should not be used as textbook RSA. It should be used with secure padding and normally only to protect a symmetric session key, while the actual transaction data is encrypted using a symmetric algorithm such as AES.

References

- Boneh, D., & Shoup, V. (2020). A Graduate Course in Applied Cryptography (Version 0.5). Stanford University. <https://crypto.stanford.edu/~dabo/cryptobook/>
- National Institute of Standards and Technology. (2023). Digital Signature Standard (DSS), FIPS 186-5. <https://doi.org/10.6028/NIST.FIPS.186-5>
- National Institute of Standards and Technology. (n.d.). Certificate - CSRC Glossary. <https://csrc.nist.gov/glossary/term/certificate>
- National Institute of Standards and Technology. (n.d.). Public key cryptography - CSRC Glossary. https://csrc.nist.gov/glossary/term/public_key_cryptography
- NIST Computer Security Resource Center. (2018). Recommendation for Pair-Wise Key-Establishment Schemes Using Discrete Logarithm Cryptography, SP 800-56A Rev. 3. <https://doi.org/10.6028/NIST.SP.800-56Ar3>
- NIST Computer Security Resource Center. (2019). Recommendation for Pair-Wise Key-Establishment Using Integer Factorization Cryptography, SP 800-56B Rev. 2. <https://doi.org/10.6028/NIST.SP.800-56Br2>
- Shoup, V. (2004). Sequences of games: A tool for taming complexity in security proofs. Cryptology ePrint Archive, Paper 2004/332. <https://eprint.iacr.org/2004/332>